UNIVERSIDADE DO VALE DO ITAJAÍ
ESCOLA POLITÉCNICA
CURSO DE CIÊNCIA DA COMPUTAÇÃO

Segurança de Sistemas Computacionais

Diego Fonseca da Silva
Leonardo Pacheco B Dias
Gustavo Gonçalves Trindade
João Victor Rodrigues Santos

MODELAGEM DE AMEAÇAS NO OWASP JUICE SHOP

TRABALHO 2
Relatório final de modelagem com DFD e STRIDE

Professor Ramicés dos Santos Silva

Itajaí (SC)
Novembro de 2026

RESUMO

Este trabalho modela ameaças do OWASP Juice Shop v20.2.0, aplicação de comércio eletrônico desenvolvida para ensino de segurança, a partir da visão de projeto. O sistema é representado por diagramas de fluxo de dados (DFD) de contexto e detalhado, com fronteiras de confiança, e quatro fluxos são analisados com STRIDE por elemento: login e sessão, cadastro e recuperação de senha, cesta e pedido, e administração e contabilidade. As ameaças são priorizadas por DREAD e ligadas a requisitos do OWASP ASVS 5.0, a CWE e à LGPD. O registro reúne 25 cenários, sete apoiados em achados do Trabalho 1 e dezoito classificados como plausíveis. A injeção SQL no login obteve a maior pontuação (9,8), por permitir sessão de administrador a partir de requisição anônima. Uma reexecução do laboratório confirmou, além dos achados históricos, a atribuição de papel privilegiado no cadastro. O trabalho entrega um plano de mitigação com critérios de aceite para os cenários de maior risco.

Palavras-chave: modelagem de ameaças; DFD; STRIDE; DREAD; OWASP Juice Shop.

QUADRO DE PARTICIPAÇÃO

Integrante	**Fluxo**	**Contribuição**
Diego Fonseca da Silva	FX1	Fundamentação, implantação, atores, ativos e pontos de entrada (C3–C6).
Leonardo Pacheco B Dias	FX2	Inventário e justificativa dos fluxos candidatos (C8).
Gustavo Gonçalves Trindade	FX3	Dependências, premissas, relação com a M1 e revisão de C6 e C8.
João Victor Rodrigues Santos	FX4	Identificação, arquitetura e DFD inicial (C1 e C2).

SUMÁRIO

1 INTRODUÇÃO 4

2 FUNDAMENTAÇÃO TEÓRICA 5

2.1 Modelagem de ameaças no ciclo de desenvolvimento seguro 5

2.2 DFD e fronteiras de confiança 5

2.3 STRIDE por elemento 6

2.4 Superfície de ataque e priorização de risco 7

2.5 Requisitos de segurança e proteção de dados pessoais 7

3 CONTEXTUALIZAÇÃO DO AMBIENTE 9

4 METODOLOGIA 11

5 MODELO DO SISTEMA 12

6 ANÁLISE DOS FLUXOS 15

6.1 FX1 — Login e uso da sessão 15

6.2 FX2 — Cadastro e recuperação de senha 17

6.3 FX3 — Cesta, checkout e registro do pedido 19

6.4 FX4 — Administração e contabilidade 22

7 VISÃO CONSOLIDADA 25

8 VALIDAÇÃO E LIMITAÇÕES 26

9 CONCLUSÃO 28

REFERÊNCIAS 29

1 INTRODUÇÃO

No Trabalho 1 a equipe avaliou o OWASP Juice Shop de fora para dentro, encontrando e classificando vulnerabilidades com OWASP, CWE e CVSS. Neste Trabalho 2 a perspectiva se inverte: o mesmo sistema é observado de dentro para fora, como na fase de projeto, respondendo às quatro perguntas de Shostack (2014): o que estamos construindo, o que pode dar errado, o que fazer a respeito e se fizemos um bom trabalho.

O objetivo é identificar e priorizar ameaças em quatro funções da versão v20.2.0 e transformar os cenários de maior risco em requisitos de segurança com critérios de aceite. O documento descreve a fundamentação, a contextualização do ambiente (C1 a C10), a metodologia, o modelo do sistema (DFD), a análise dos quatro fluxos, a visão consolidada e a validação do modelo com comparação ao Trabalho 1.

2 FUNDAMENTAÇÃO TEÓRICA

2.1 Modelagem de ameaças no ciclo de desenvolvimento seguro

A modelagem de ameaças é a atividade de examinar um sistema, ainda na perspectiva de projeto, para antecipar as condições em que um agente mal-intencionado poderia comprometer seus ativos durante o uso previsto. Em vez de partir de uma falha já observada, como no teste de invasão, ela parte da estrutura do sistema e pergunta, de forma sistemática, onde a confiança é depositada e onde essa confiança pode ser quebrada. No ciclo de vida de desenvolvimento seguro (SSDLC), esse exame é posicionado cedo, porque corrigir uma decisão de projeto é mais barato do que remediar uma vulnerabilidade em produção; o Secure Software Development Framework recomenda, na prática PW.1.1, modelar ameaças e superfícies de ataque e considerar relatórios anteriores de vulnerabilidades como insumo da análise (Souppaya, Scarfone e Dodson, 2022). Neste trabalho, os achados do Trabalho 1 cumprem exatamente esse papel: orientam a análise para os pontos cujo comportamento já foi observado.

Shostack (2014) organiza a modelagem em quatro perguntas que estruturam todo este relatório: o que estamos construindo, o que pode dar errado, o que vamos fazer a respeito e se fizemos um bom trabalho. A primeira pergunta é respondida pela documentação do sistema; a segunda, pela identificação sistemática de ameaças; a terceira, pela priorização e pelo tratamento; e a quarta, pela validação do próprio modelo. Tuma, Çalikli e Scandariato (2018), em revisão sistemática, observam que a qualidade de uma análise de ameaças depende menos da técnica isolada e mais do rigor do procedimento e da verificação dos resultados. Por isso, adota-se aqui a distinção explícita entre evidência de execução, inspeção de código e hipótese de ataque, que indica, para cada cenário, que tipo de teste poderia confirmá-lo ou refutá-lo.

2.2 DFD e fronteiras de confiança

O Diagrama de Fluxo de Dados (DFD) é a notação escolhida para responder à primeira pergunta. Ele representa quatro tipos de elemento: entidades externas, que fornecem ou recebem dados fora do sistema modelado; processos, que transformam dados; armazenamentos, que os conservam; e fluxos, que transportam a informação entre os demais elementos (Hernan et al., 2006). Cada elemento recebe um identificador único, reutilizado em todas as tabelas do relatório, o que garante a rastreabilidade entre o diagrama, as fichas, o

registro de ameaças e as mitigações. O DFD descreve por onde os dados passam e onde ficam, e não a sequência de decisões do programa; não é, portanto, um fluxograma.

A fronteira de confiança é o conceito central do diagrama para a segurança: ela marca o ponto em que mudam as garantias com que os dados podem ser usados ou as permissões necessárias para acessá-los. Todo fluxo que cruza uma fronteira merece atenção redobrada, porque é ali que um dado antes considerado confiável passa a ser suspeito, ou vice-versa. O DFD de contexto (nível 0) concentra a aplicação em um único processo e explicita as entidades externas e as interfaces; o DFD de nível 1 decompõe a operação interna em processos e armazenamentos, com todas as fronteiras relevantes. É sobre o nível 1 que os fluxos são recortados para a análise.

2.3 STRIDE por elemento

STRIDE é o método usado para responder à segunda pergunta, o que pode dar errado. A sigla reúne seis categorias de ameaça, cada uma associada à violação de uma propriedade de segurança, conforme o Quadro 1: Spoofing viola a autenticidade, Tampering a integridade, Repudiation o não repúdio, Information Disclosure a confidencialidade, Denial of Service a disponibilidade e Elevation of Privilege a autorização (Hernan et al., 2006). A classificação orienta o analista a verificar, elemento por elemento, de que modo cada propriedade poderia ser comprometida.

A variante STRIDE por elemento, formalizada pela Microsoft, reconhece que nem toda categoria se aplica a todo tipo de elemento e define o mínimo a analisar em cada um: entidades externas são examinadas quanto a Spoofing e Repudiation; processos, quanto às seis categorias; fluxos e armazenamentos, quanto a Tampering, Information Disclosure e Denial of Service, acrescentando-se Repudiation aos armazenamentos que guardam registros de auditoria. O preenchimento da matriz fornece cobertura de análise, mas não encerra a avaliação: Scandariato, Wuyts e Joosen (2015) mostram que a técnica pode produzir tanto ameaças incorretas quanto omissões, de modo que a verificação de cada cenário depende de sua aderência à rota, ao papel do agente e à evidência disponível. Cada ameaça aceita é reescrita no formato padrão, descrevendo o agente, a ação, o elemento afetado, a fraqueza explorada e o impacto, para evitar enunciados genéricos.

Quadro 1 — Categorias STRIDE e propriedades de segurança

Categoria	Significado	Propriedade
S — Spoofing	Falsificação de identidade	Autenticidade
T — Tampering	Alteração indevida de dados ou lógica	Integridade
R — Repudiation	Contestação de autoria sem evidência	Não repúdio

I — Information Disclosure	Exposição de informação a agente indevido	Confidencialidade
D — Denial of Service	Indisponibilidade ou degradação	Disponibilidade
E — Elevation of Privilege	Acesso além da permissão	Autorização

Fonte: adaptado de Hernan et al. (2006).

2.4 Superfície de ataque e priorização de risco

A superfície de ataque compreende o conjunto de canais, métodos e dados por meio dos quais um agente consegue interagir com o sistema. Manadhata e Wing (2011) tratam esses elementos como recursos que contribuem para a exposição: cada rota alcançável, parâmetro, cabeçalho, cookie, token ou arquivo amplia a superfície por permitir uma operação distinta. Mapear a superfície, organizada em categorias como rede, interface de usuário, interface administrativa, integração externa e dados, é condição para que a análise de ameaças seja abrangente, pois cada ponto de entrada é um candidato a ser examinado com STRIDE.

Identificadas as ameaças, é preciso priorizá-las, já que nem todas têm o mesmo risco. Adota-se o DREAD, que decompõe o risco em cinco dimensões, cada uma com nota de 1 a 10: dano potencial, reprodutibilidade, explorabilidade, usuários afetados e facilidade de descoberta (Meier et al., 2003). O risco é a média aritmética das cinco notas, na escala da disciplina (baixo até 3,9; médio de 4,0 a 6,9; alto a partir de 7,0). Por ser um método de julgamento, cada nota é acompanhada de uma justificativa, e os empates são resolvidos por critério explícito. Alves et al. (2024) aplicam STRIDE e DREAD de forma combinada a um sistema IoT, com identificação e priorização em momentos distintos, abordagem semelhante à adotada aqui.

2.5 Requisitos de segurança e proteção de dados pessoais

A terceira pergunta de Shostack exige mitigações concretas e verificáveis, e não recomendações vagas. Para ancorá-las, cada medida é ligada a um requisito do OWASP Application Security Verification Standard (ASVS) 5.0, que fornece requisitos testáveis de autenticação, gestão de sessão e controle de acesso; a um identificador do Common Weakness Enumeration (CWE), que classifica a fraqueza subjacente, mantendo a continuidade com a classificação do Trabalho 1; e, quando há tratamento de dados pessoais, a dispositivos da Lei Geral de Proteção de Dados (LGPD). O art. 46 da LGPD impõe medidas técnicas e administrativas de proteção contra acessos não autorizados, e o princípio da necessidade (art. 6º, III) orienta a minimização de dados em respostas, tokens e logs (Brasil, 2018). Carneiro, Kudo e Bulcão Neto (2024) propõem justamente transformar disposições legais em padrões

de requisitos de software, o que sustenta a tradução, neste trabalho, de obrigações da LGPD em critérios de aceite concretos.

3 CONTEXTUALIZAÇÃO DO AMBIENTE

O capítulo responde às perguntas C1 a C10 do roteiro, de forma objetiva.

C1–C3 (identificação, arquitetura e implantação).

O OWASP Juice Shop é uma loja fictícia mantida por colaboradores da OWASP. A M1 implantou a imagem oficial bkimminich/juice-shop:v20.2.0 (digest sha256:8739101ade29358abb5469ee66ae78e582c97ed0a5543a4ad102e5fa5193526b). A interface é uma SPA em Angular/TypeScript; o back-end é Node.js com Express expondo JSON, com SQLite acessado por Sequelize, coleções em MarsDB e comprovantes em PDF no diretório ftp/. A autenticação local emite JWT RS256. O Compose publica a porta 3000 apenas em 127.0.0.1, em rede bridge isolada, com execução como UID 65532.

Quadro 2 — Atores e permissões (C4)

Ator / papel	Funções e limites
E1 / visitante	Sem sessão. Usa cadastro, recuperação, login, catálogo e arquivos públicos.
E2 / cliente	Opera a própria cesta e pedidos (customer e deluxe).
E3 / admin	Consulta usuários e modera feedbacks; a permissão na API é verificada à parte.
E4 / accounting	Consulta pedidos e altera entrega em rotas com verificação de papel.
Serviços externos	Google OAuth e chatbot aparecem em configuração, fora do recorte.

Fonte: OWASP Juice Shop (2026) e Silva et al. (2026).

Quadro 3 — Ativos e classificação de dados (C5)

Conjunto de dados	Classificação (C5)
E-mail, nome, endereço, telefone, IP	Dado pessoal quando vinculável a titular identificável.
Senha, hash, resposta de segurança, JWT, TOTP	Credenciais/segredos de autenticação.
Cesta, pedido, endereço, comprovante	Dado pessoal quando associado à conta.
Cartão e carteira (simulação)	Dados de pagamento fictícios no laboratório.

Fonte: Brasil (2018) e OWASP Juice Shop (2026).

Quadro 4 — Superfície de ataque por categoria (C6)

Categoria (C6)	Entradas e evidência
Rede	HTTP TCP 3000 em loopback; Socket.IO integra o servidor (TB-01, TB-02).
Interface de usuário	Login, cadastro, recuperação, busca, checkout (M1: login, reset, cesta).
Administrativa	/#/administration, /#/accounting e respectivas APIs.
Integração externa	Google OAuth, /b2b/v2/orders, /rest/chat (código/config, sem uso na M1).
Dados e arquivos	Corpos JSON, cookies, JWT, SQLite e PDFs; /ftp/ comprovado em V5.

Fonte: OWASP Juice Shop (2026) e Silva et al. (2026).

C7–C9 (dependências, seleção e premissas).

Entre as dependências relevantes estão Express e finale-rest (CRUD e middlewares), Sequelize e sqlite3 (persistência; a consulta bruta de login não usa a proteção do ORM), jsonwebtoken 0.4.0 e express-jwt 0.1.3 (emissão e validação de JWT), express-rate-limit (cota do reset), MarsDB e Socket.IO, e Morgan/serve-index/PDFKit. Foram selecionados quatro fluxos (Quadro 5): FX1 cobre a sessão, FX2 e FX3 tratam dados pessoais e FX4 concentra função privilegiada; todos cruzam ao menos uma fronteira e três contêm achados da M1. Assume-se a integridade do host, do Docker e da rede local; carga, expiração, concorrência e rotas não analisadas ficam fora do escopo.

Quadro 5 — Fluxos candidatos e critérios de seleção (C8)

ID	Funcionalidade	Justificativa da seleção
FX1	Login e uso da sessão	Sustenta a identidade das demais funções. V1, V2, V6.
FX2	Cadastro e recuperação de senha	Grava dados de conta e expõe a recuperação. V7.
FX3	Cesta, checkout e pedido	Trata dados de compra e comprovante. V3, V4, V5.
FX4	Administração e contabilidade	Função privilegiada sobre vários titulares.
FX5	Login com Google OAuth (reserva)	Depende de provedor externo; não comprovado na M1.

Fonte: elaboração própria.

C10 (relação com o Trabalho 1).

Quadro 6 — Rastreabilidade dos achados da M1 (C10)

ID	OWASP / CVSS	Efeito observado	Local na M2
V1	A03 / 9,1	SQL injection no login e entrada como admin.	FX1 · T-FX1-02
V2	A02 / 6,5	Hash MD5 no payload do JWT.	FX1 · T-FX1-04
V3	A01 / 6,5	Cesta da conta A lida com JWT da conta B.	FX3 · T-FX3-06
V4	A05 / 5,3	Erro detalhado em rota de cesta.	FX3 · T-FX3-04
V5	A05 / 7,5	Listagem e download anônimos em /ftp/.	FX3 · apoio T-FX3-07
V6	A07 / 6,5	15 falhas 401 seguidas de login sem bloqueio.	FX1 · T-FX1-01
V7	A04 / 9,1	Pergunta consultável e reset no 5º palpite.	FX2 · T-FX2-01/04

Fonte: Silva et al. (2026) e elaboração própria.

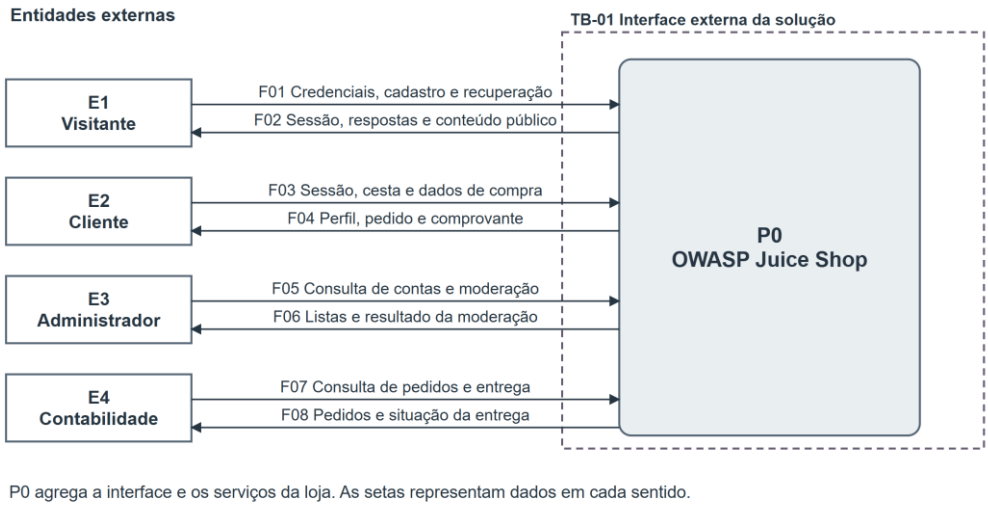
4 METODOLOGIA

A análise foi documental, a partir do Compose, do relatório e dos artefatos da M1, do código e dos testes da tag v20.2.0 e de uma reexecução do laboratório em 8 de novembro de 2026. Os identificadores E, P, D, F e TB designam entidades, processos, armazenamentos, fluxos e fronteiras; cada ameaça recebe um identificador T-FX<n>-<seq> que liga a ficha, a matriz, o registro e a conclusão. O estado Confirmada no T1 é reservado ao comportamento observado em requisição, resposta ou captura da M1; Plausível identifica hipótese fundamentada em código, documentação ou teste, sem reprodução pela equipe. A pontuação DREAD usa a média das cinco notas, cada uma justificada, na escala da disciplina; empates são resolvidos pela confirmação histórica, pelo dano e pelo identificador. Cada mitigação indica tipo de controle, camada, critério de aceite e referência (ASVS 5.0, CWE, Cheat Sheets e LGPD).

5 MODELO DO SISTEMA

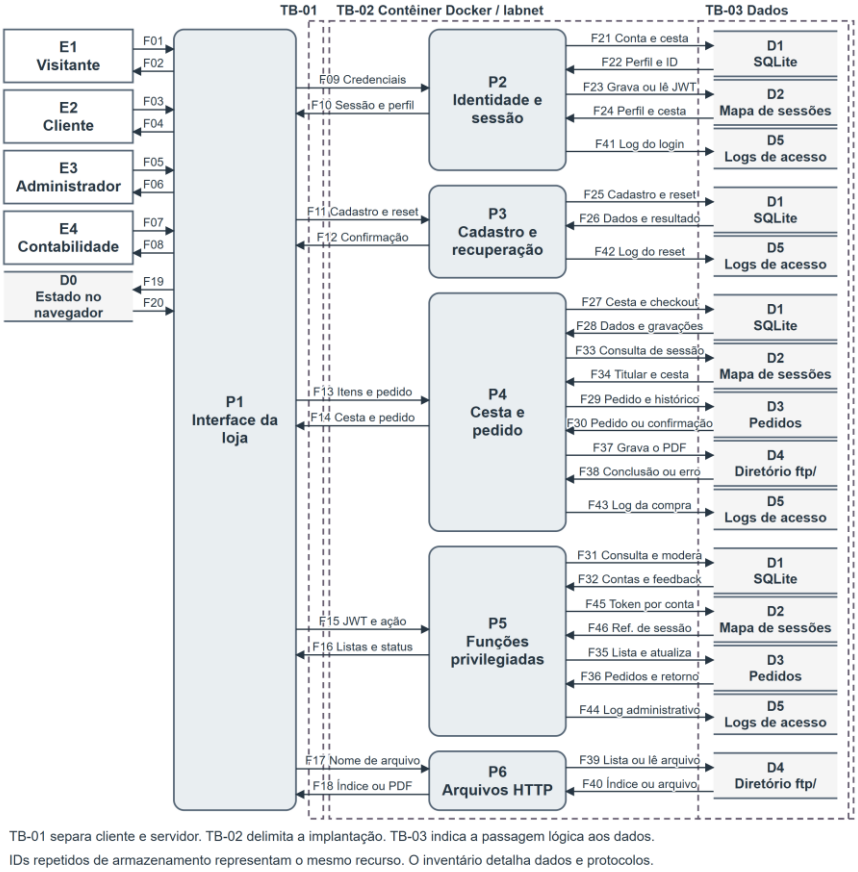
O DFD de contexto (Figura 1) concentra a aplicação em um processo (P0) e suas entidades externas. O DFD de nível 1 (Figura 2) decompõe o serviço Express em processos (P2 identidade, P3 cadastro, P4 cesta, P5 funções privilegiadas, P6 arquivos) e explicita os armazenamentos e as fronteiras de confiança.

Figura 1 — DFD de contexto do OWASP Juice Shop



Fonte: elaboração própria.

Figura 2 — DFD de nível 1 com fronteiras de confiança



TB-01 separa cliente e servidor. TB-02 delimita a implantação. TB-03 indica a passagem lógica aos dados.
IDs repetidos de armazenamento representam o mesmo recurso. O inventário detalha dados e protocolos.

Fonte: elaboração própria.

Quadro 7 — Inventário dos elementos do DFD

ID	Tipo	Responsabilidade	Tecnologia
P1	Processo	Interface da loja (SPA) no navegador.	Angular
P2	Processo	Identidade e sessão; emite e valida JWT.	Express, jsonwebtoken
P3	Processo	Cadastro e recuperação de senha.	Express, finale-rest
P4	Processo	Cesta, pedido e comprovante.	Express, MarsDB, PDFKit
P5	Processo	Funções administrativas e contábeis.	Express, finale-rest
P6	Processo	Arquivos HTTP (ftp/).	serve-index, sendFile
D1	Armazenamento	Contas, respostas, cestas, pedidos, feedbacks.	SQLite
D2	Armazenamento	Mapa de sessões (JWT→perfil).	Memória Node.js
D4	Armazenamento	Diretório ftp/ (exemplos e comprovantes).	Sistema de arquivos
D5	Armazenamento	Logs de acesso HTTP.	Morgan

Fonte: OWASP Juice Shop (2026) e elaboração própria.

Quadro 8 — Fronteiras de confiança

Fronteira	Lados	Mudança de confiança
TB-01	Cliente | servidor	Dados controlados pelo cliente chegam a rotas que autenticam, autorizam e validam.
TB-02	Host | contêiner	Encaminhamento da porta do host ao processo;

		loopback restringe a publicação.
TB-03	Aplicação | armazenamentos	A requisição passa a leitura/gravação de ativos internos, com permissões do processo.

Fonte: elaboração própria.

6 ANÁLISE DOS FLUXOS

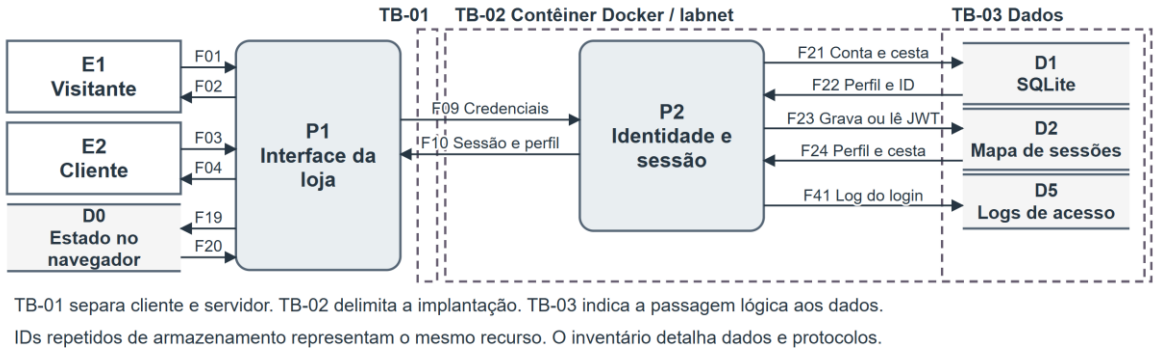
Para cada fluxo apresentam-se a ficha resumida, o recorte do DFD, a matriz STRIDE dos elementos com ameaça registrada e o registro consolidado (cenário, prioridade e mitigação). As respostas do questionário obrigatório são sintetizadas no texto de cada fluxo.

6.1 FX1 — Login e uso da sessão

O visitante envia e-mail e senha a P2, que consulta D1, emite um JWT e registra a identidade no mapa de sessões (D2). A SPA guarda o token e o reutiliza nas rotas protegidas. O fluxo cruza TB-01/TB-02 (F09, F10) e TB-03 (F21–F24, F41). Controles observados: assinatura RS256, resposta 401 a credenciais inválidas, hash de senha e log HTTP. A ameaça mais grave é a injeção no login, que leva uma requisição anônima à identidade administrativa.

Ficha do fluxo	
Responsável / revisor	Diego Fonseca da Silva / Gustavo Gonçalves Trindade
Ator e gatilho	Visitante E1 envia o formulário de login; o cliente E2 atua após a emissão.
Pré-condições	Conta cadastrada, aplicação acessível e credenciais válidas.
Resultado esperado	Token para a conta, ID de cesta associado e perfil nas chamadas de sessão.

Figura 3 — Recorte do DFD do FX1



Fonte: elaboração própria.

Quadro 9 — Matriz STRIDE do FX1 (elementos com ameaça; números = sequência T-FX1-0x)

Elemento	**S**	**T**	**R**	**I**	**D**	**E**
E1 Visitante	01		03			
P2 Identidade	01	02	03	04	05	06
F09 credenciais		02				
D2 Mapa de sessões				04	05	
D5 Logs de acesso			03			

Fonte: elaboração própria.

Questionário obrigatório. As respostas às perguntas do template são sintetizadas a seguir.

Compreensão (Q1–Q7). O objetivo é autenticar o usuário e emitir a sessão que sustenta compras e funções privilegiadas, o que torna o fluxo o mais sensível do sistema. É iniciado pelo visitante (E1) e usado pelo cliente (E2); os papéis admin e accounting compartilham a mesma entrada de login. Percorre P1 e P2 por F09/F10 (HTTP/JSON), consulta o SQLite (D1) por F21/F22, usa o mapa de sessões (D2) por F23/F24 e grava log em D5 (F41), cruzando TB-01, TB-02 e TB-03. Trafegam e-mail, senha e JWT, além de identificadores pessoais; a senha é guardada como hash em D1. Os pontos de entrada são o corpo JSON do login, o cabeçalho Authorization, o cookie e o parâmetro fields do whoami. Já existem a assinatura RS256, a resposta 401 a credenciais inválidas, o hash de senha, o TOTP condicional e o log HTTP.

Spoofing, Tampering e Repúdio (S/T/R). Cada elemento prova identidade por senha e, nas rotas protegidas, por JWT; a injeção permite assumir o papel admin sem a senha correta (T-FX1-02). O e-mail é interpolado na consulta de login, o que altera sua lógica (V1), e o servidor não revalida o predicado de senha. O log registra origem e horário, mas não correlaciona de forma inequívoca tentativa, conta, sessão e resultado, o que permite contestação (T-FX1-03).

Divulgação, Disponibilidade e Elevação (I/D/E). O JWT serializa o modelo da conta e expõe o campo password (hash MD5), sem expiração observada (V2). A emissão repetida de sessões alimenta o mapa D2 sem limite nem expurgo identificados (T-FX1-05). A prova de assinatura, isolada, não decide papel; a chave privada embutida na distribuição permitiria forjar tokens privilegiados (T-FX1-06).

Fechamento (V1–V3). A ameaça mais grave é T-FX1-02 (9,8). Foram confirmadas na M1 a injeção (V1), o hash no JWT (V2) e a sequência de falhas de login (V6); esgotamento do mapa e uso da chave permanecem hipóteses documentais. Assume-se a integridade do host e da rede; a verificação de expiração rota a rota exige novo ensaio.

Quadro 13 — Registro de ameaças do FX1

ID	Cenário (categoria STRIDE)	DREAD · Status	Mitigação (ASVS / CWE / LGPD)
T-FX1-01	S · Força bruta no login sem bloqueio efetivo (V6).	8,0 · T1 (V6)	Atraso progressivo por conta e MFA em contas privilegiadas (ASVS 6.1.1; CWE-307; LGPD 46).
T-FX1-02	T/E · E-mail concatenado à consulta inicia sessão de administrador (V1).	9,8 · T1 (V1)	Consulta parametrizada e verificação de senha separada (ASVS 1.2.4; CWE-89).
T-FX1-03	R · Log não correlaciona tentativa, conta, sessão e resultado.	6,4 · Plausível	Evento estruturado em trilha protegida (ASVS 16.2.1; CWE-778).

T-FX1-04	I · JWT inclui o campo password (MD5) e não expira (V2).	8,6 · T1 (V2)	Claims mínimos e migração para Argon2id (ASVS 14.1.1, 11.4.1; CWE-916).
T-FX1-05	D · Emissão repetida de sessões esgota o mapa D2.	6,8 · Plausível	Expiração efetiva e limites por conta (ASVS 2.4.1, 7.1.2; CWE-400).
T-FX1-06	E · Chave de assinatura embutida na distribuição.	8,4 · Plausível	Chave por implantação em cofre e verificação de emissor/expiração (ASVS 13.3.1; CWE-321).

Fonte: elaboração própria.

Justificativa das notas DREAD (cenários principais).

T-FX1-02 (9,8): dano 10, a entrada como administrador expõe dados e funções de todos os titulares; reprodutibilidade 10, a mesma requisição repete o efeito; explorabilidade 10, dispensa sessão prévia e usa ferramenta comum; usuários afetados 10, atinge a instância inteira; descoberta 9, o campo é evidente no formulário de login.

T-FX1-04 (8,6): dano 8, expõe o hash da senha para quebra offline; reprodutibilidade 10, o token é legível pelo portador; explorabilidade 8, exige obter um token válido; usuários 8, afeta cada conta autenticada; descoberta 9, o campo aparece no próprio payload.

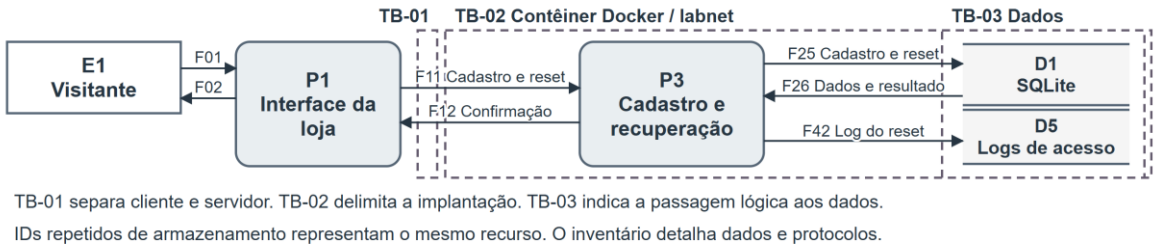
Conclusão do fluxo. A ameaça prioritária é T-FX1-02 (9,8): a entrada anônima alcança a identidade administrativa, com efeito sobre dados e funções de outros titulares. T-FX1-02, 04 e 01 foram confirmadas na M1; esgotamento e uso da chave permanecem hipóteses documentais.

6.2 FX2 — Cadastro e recuperação de senha

O visitante cria conta em P3 (grava em D1), associa pergunta e resposta de segurança e redefine a senha. O fluxo trata dados pessoais e expõe o mecanismo de recuperação. Controles observados: cota de reset (express-rate-limit) e hash de senha. Duas fraquezas se destacam: a recuperação por pergunta publicamente consultável e a atribuição de papel no cadastro, reproduzida na M2.

Ficha do fluxo	
Responsável / revisor	Leonardo Pacheco B Dias / Diego Fonseca da Silva
Ator e gatilho	Visitante E1 cria conta ou solicita a redefinição de senha.
Pré-condições	E-mail válido e pergunta de segurança associada à conta.
Resultado esperado	Conta criada (com papel) ou senha redefinida.

Figura 4 — Recorte do DFD do FX2



Fonte: elaboração própria.

Quadro 10 — Matriz STRIDE do FX2 (elementos com ameaça; números = sequência T-FX2-0x)

Elemento	S	T	R	I	D	E
E1 Visitante	01		03			
P3 Cadastro/recuperação	01	02	03	04	05	06
F11 cadastro/reset		02		04		06
D1 SQLite				04		

Fonte: elaboração própria.

Questionário obrigatório. As respostas às perguntas do template são sintetizadas a seguir.

Compreensão (Q1–Q7). O fluxo cria contas e redefine senhas, gravando dados pessoais no SQLite (D1) por meio de P3; é iniciado pelo visitante (E1). Percorre P1 e P3 por F11/F12, grava e consulta D1 por F25/F26 e registra o reset em D5 (F42), cruzando TB-01 e TB-03. Trafegam e-mail, senha, pergunta e resposta de segurança (dado pessoal e segredo). Os pontos de entrada incluem o corpo do cadastro, com o campo de papel, a consulta da pergunta por e-mail e o corpo do reset. Já existem a cota de reset (limite de taxa) e o hash de senha.

Spoofing, Tampering e Repúdio (S/T/R). A recuperação por pergunta de segurança permite tomar a conta no quinto palpite, dentro da cota (V7). A associação da resposta de segurança pode ser indevidamente vinculada quando não presa à conta autenticada (T-FX2-02). A redefinição não guarda trilha de autoria suficiente para apuração (T-FX2-03).

Divulgação, Disponibilidade e Elevação (I/D/E). A pergunta de segurança é retornada a partir do e-mail, o que enumera contas (T-FX2-04). Cadastros automatizados consomem recursos sem contenção específica (T-FX2-05). O cadastro aceita o atributo de papel enviado pelo cliente e cria uma conta administradora (T-FX2-06), cenário reproduzido na M2.

Fechamento (V1–V3). A ameaça mais grave é T-FX2-06 (9,0), reproduzida na M2. A recuperação (T-FX2-01 e 04) foi confirmada na M1 (V7). Premissa: a unicidade da resposta

de segurança não é garantida, e o comportamento após o esgotamento da cota requer novo ensaio.

Quadro 14 — Registro de ameaças do FX2

ID	Cenário (categoria STRIDE)	DREAD · Status	Mitigação (ASVS / CWE / LGPD)
T-FX2-01	S · Pergunta consultável e reset no 5º palpite dentro da cota (V7).	8,8 · T1 (V7)	Recuperação de uso único com token temporário (ASVS 6.3.3; CWE-640; LGPD 46).
T-FX2-02	T · Associação indevida de resposta de segurança.	6,6 · Plausível	Vincular a resposta à conta autenticada (ASVS 6.3.1; CWE-640).
T-FX2-03	R · Redefinição de senha sem trilha de autoria.	5,2 · Plausível	Registrar evento de reset com origem e horário (ASVS 16.2.1; CWE-778).
T-FX2-04	I · Pergunta de segurança exposta por e-mail.	7,4 · T1 (V7)	Não enumerar contas; resposta uniforme (ASVS 6.3.2; CWE-204; LGPD 6, III).
T-FX2-05	D · Cadastros automatizados consomem recursos.	5,8 · Plausível	Limite de taxa e verificação anti-automação (ASVS 2.2.1; CWE-799).
T-FX2-06	E · role:admin aceito do cliente cria conta administradora (reproduzida na M2).	9,0 · Plausível	Allowlist de campos e papel definido no servidor (ASVS 1.2.3; CWE-915).

Fonte: elaboração própria.

Justificativa das notas DREAD (cenários principais).

T-FX2-06 (9,0): dano 10, concede papel administrativo sobre todos os titulares; reprodutibilidade 9, basta repetir o cadastro; explorabilidade 9, um corpo JSON com o campo de papel; usuários 9, afeta a instância; descoberta 8, o atributo é inferível do modelo de dados.

T-FX2-01 (8,8): dano 9, resulta em tomada de conta; reprodutibilidade 9, a pergunta é consultável; explorabilidade 9, ocorre dentro da cota; usuários 8, contas com perguntas fracas; descoberta 8, a rota é pública.

Conclusão do fluxo. T-FX2-06 (9,0) é a de maior risco e foi reproduzida ao vivo na M2: o cadastro aceita o atributo de papel enviado pelo cliente. A recuperação (T-FX2-01/04) foi confirmada na M1. As correções são a atribuição de papel no servidor e a recuperação de uso único.

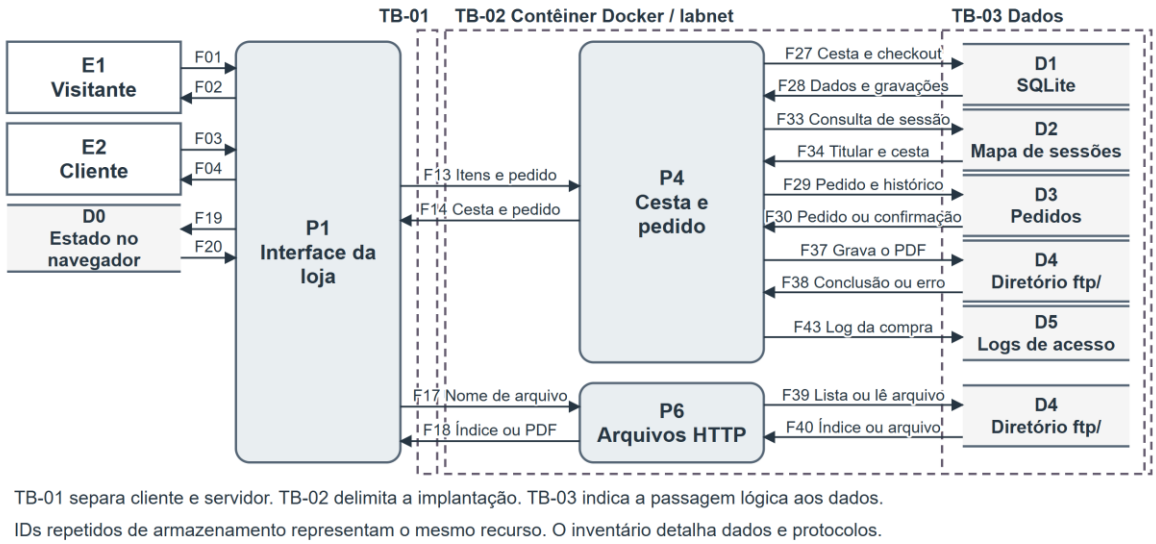
6.3 FX3 — Cesta, checkout e registro do pedido

O cliente opera a cesta em P4, calcula o pedido e gera o comprovante em PDF (D4). O fluxo trata dados de compra e comprovante e cruza TB-01/TB-03. Controles observados: exigência de token nas rotas de cesta e HTTPS ausente no laboratório (HTTP de loopback). O

ponto central é a autorização: reconhecer a sessão não garante a titularidade do objeto acessado.

Ficha do fluxo	
Responsável / revisor	Gustavo Gonçalves Trindade / João Victor Rodrigues Santos
Ator e gatilho	Cliente E2 adiciona itens à cesta e conclui a compra.
Pré-condições	Sessão válida e cesta associada à conta.
Resultado esperado	Pedido registrado e comprovante em PDF gerado.

Figura 5 — Recorte do DFD do FX3



Fonte: elaboração própria.

Quadro 11 — Matriz STRIDE do FX3 (elementos com ameaça; números = sequência T-FX3-0x)

Elemento	**S**	**T**	**R**	**I**	**D**	**E**
P4 Cesta e pedido	01	02	03	04	05	06
F13/F14 itens e pedido		02		06		
D4 Diretório ftp/				06	05	
Resposta de erro				04		

Fonte: elaboração própria.

Questionário obrigatório. As respostas às perguntas do template são sintetizadas a seguir.

Compreensão (Q1–Q7). O fluxo gerencia a cesta, calcula o pedido e gera o comprovante em PDF por meio de P4, com gravação em D1 e no diretório ftp/ (D4); é iniciado pelo cliente (E2). Percorre P1 e P4 por F13/F14 e cruza TB-01 e TB-03. Trafegam itens, valores, endereço e cartão sintético, além do comprovante, que é dado pessoal quando associado à conta. Os pontos de entrada incluem os identificadores de cesta e pedido, o corpo da compra e o nome de arquivo. Já existe a exigência de token nas rotas de cesta; o laboratório usa HTTP sem TLS.

Spoofing, Tampering e Repúdio (S/T/R). A reutilização de uma sessão de comprador permitiria agir por outro (T-FX3-01). Referências a uma cesta alheia podem ser usadas no checkout, por falta de verificação de propriedade (T-FX3-02). O pedido não correlaciona os eventos que o compõem, dificultando a apuração (T-FX3-03).

Divulgação, Disponibilidade e Elevação (I/D/E). A resposta de erro expõe detalhes internos do framework (V4), e o diretório ftp/ lista documentos de forma anônima (V5). A geração repetida de comprovantes pode saturar o disco (T-FX3-05). Com um token válido, lê-se a cesta de outro titular (V3), pois a autorização por objeto não é aplicada na rota.

Fechamento (V1–V3). A ameaça mais grave é T-FX3-06 (8,4), confirmada na M1 (V3); o erro verboso (V4) e a listagem do diretório (V5) também se confirmam. Premissa: a rede entre P4 e D4 é interna; a leitura de um comprovante de pedido específico permanece hipótese (T-FX3-07), apoiada por V5.

Quadro 15 — Registro de ameaças do FX3

ID	Cenário (categoria STRIDE)	DREAD · Status	Mitigação (ASVS / CWE / LGPD)
T-FX3-01	S · Reutilização de sessão de comprador.	6,2 · Plausível	Revogação e expiração efetiva da sessão (ASVS 3.3.1; CWE-613).
T-FX3-02	T · Checkout com referências de cesta alheia.	7,8 · Plausível	Verificar propriedade do recurso a cada requisição (ASVS 4.2.1; CWE-639).
T-FX3-03	R · Pedido sem correlação de eventos.	5,6 · Plausível	Trilha de pedido com usuário e horário (ASVS 16.2.1; CWE-778).
T-FX3-04	I · Erro verboso com detalhes internos (V4).	6,0 · T1 (V4)	Erro genérico e cabeçalhos de segurança (ASVS 7.4.1; CWE-209).
T-FX3-05	D · Geração repetida de comprovantes satura o disco.	6,8 · Plausível	Quota de PDF, paginação e limites (ASVS 12.1.1; CWE-400).
T-FX3-06	I/E · Leitura da cesta de outro titular com JWT válido (V3).	8,4 · T1 (V3)	Autorização por objeto na rota de cesta (ASVS 4.2.1; CWE-639; A01).

Fonte: elaboração própria.

Justificativa das notas DREAD (cenários principais).

T-FX3-06 (8,4): dano 8, expõe itens e dados de compra de outro titular; reprodutibilidade 9, basta trocar o identificador; explorabilidade 8, exige uma conta válida; usuários 9, qualquer titular; descoberta 8, o identificador aparece no cliente.

T-FX3-02 (7,8): dano 8, viabiliza fraude de pedido; reprodutibilidade 8, depende de estado alcançável; explorabilidade 7, exige conhecer a referência; usuários 8; descoberta 8.

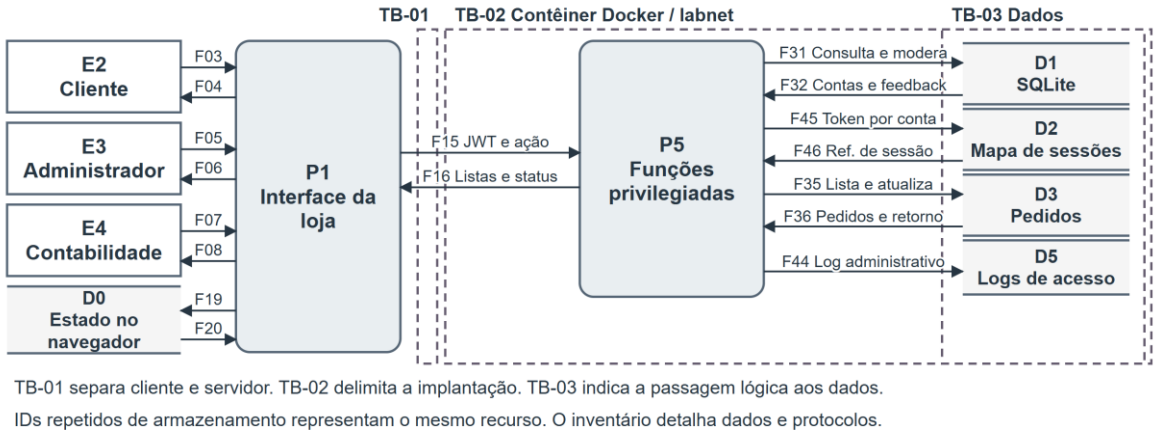
Conclusão do fluxo. T-FX3-06 (8,4) foi confirmada na M1: com um token válido lê-se a cesta de outra conta; sem token, a rota recusa. V5 comprova a exposição do diretório /ftp/, que sustenta a hipótese T-FX3-07 sobre o comprovante de pedido. A correção é a política de titularidade por objeto e servir arquivos só via API autorizada.

6.4 FX4 — Administração e contabilidade

Os papéis admin e accounting operam funções privilegiadas em P5 sobre dados de vários titulares. Controles observados: autenticação nas listagens e verificação de papel nas rotas de pedidos contábeis; a análise verifica se a mesma verificação alcança todas as rotas. A reprodução M2 alcançou o painel de administração, com a lista de e-mails e feedbacks (Figura 5).

Ficha do fluxo	
Responsável / revisor	João Victor Rodrigues Santos / Leonardo Pacheco B Dias
Ator e gatilho	Admin E3 ou accounting E4 executa operação privilegiada.
Pré-condições	Sessão com papel admin ou accounting.
Resultado esperado	Consulta, moderação ou alteração de entrega aplicada.

Figura 6 — Recorte do DFD do FX4



Fonte: elaboração própria.

Quadro 12 — Matriz STRIDE do FX4 (elementos com ameaça; números = sequência T-FX4-0x)

Elemento	**S**	**T**	**R**	**I**	**D**	**E**
P5 Funções privilegiadas	01	02	03	04	05	06
F16 dados e operações		02		04		06
D1 SQLite				04	05	

Fonte: elaboração própria.

Questionário obrigatório. As respostas às perguntas do template são sintetizadas a seguir.

Compreensão (Q1–Q7). O fluxo executa funções administrativas e contábeis sobre dados de vários titulares por meio de P5; é iniciado pelos papéis admin (E3) e accounting (E4). Percorre P1 e P5 por F15/F16, consulta e altera o SQLite (D1) e cruza TB-01 e TB-03. Trafegam dados de contas, feedbacks, pedidos e status de entrega. Os pontos de entrada incluem o JWT, os identificadores e os comandos de moderação. Já existem a autenticação nas listagens e a verificação de papel nas rotas de pedidos contábeis.

Spoofing, Tampering e Repúdio (S/T/R). Uma sessão contábil reutilizada após o desligamento permitiria agir sem o papel atual (T-FX4-01). A atualização de entrega pode se basear em estado enviado pelo cliente, sem revalidação (T-FX4-02). A moderação e a entrega carecem de trilha que impeça a contestação (T-FX4-03).

Divulgação, Disponibilidade e Elevação (I/D/E). A consulta de usuários por conta sem papel admin exporia e-mails de muitos titulares (T-FX4-04). A listagem sem limite de volume degrada o serviço (T-FX4-05). A exclusão de feedback sem exigir papel admin revela verificação de função desigual entre rotas (T-FX4-06).

Fechamento (V1–V3). As ameaças mais graves são T-FX4-04 (8,6) e T-FX4-06 (8,2). A reprodução M2 alcançou o painel de administração, com a lista de e-mails e feedbacks. Os cenários permanecem plausíveis até a verificação rota a rota, com duas contas de cliente e os papéis admin e accounting.

Quadro 16 — Registro de ameaças do FX4

ID	Cenário (categoria STRIDE)	DREAD · Status	Mitigação (ASVS / CWE / LGPD)
T-FX4-01	S · Reuso de sessão contábil após desligamento.	6,0 · Plausível	Expiração e revalidação de papel na sessão (ASVS 3.3.1; CWE-613).
T-FX4-02	T · Atualização de entrega baseada em estado do cliente.	6,4 · Plausível	Validar transição no servidor (ASVS 4.2.1; CWE-639).
T-FX4-03	R · Repúdio de moderação e entrega.	5,4 · Plausível	Trilha de ações privilegiadas (ASVS 16.2.1; CWE-778).
T-FX4-04	I · Consulta de usuários por conta sem papel admin.	8,6 · Plausível	Política de função por rota, negar por padrão (ASVS 4.1.1; CWE-284; LGPD 46).
T-FX4-05	D · Listagem sem limite de volume.	6,6 · Plausível	Paginação e limites de resposta (ASVS 12.1.1; CWE-770).
T-FX4-06	E · Exclusão de feedback por conta sem papel.	8,2 · Plausível	Verificação de papel por rota (ASVS 4.1.3; CWE-285; A01).

Fonte: elaboração própria.

Justificativa das notas DREAD (cenários principais).

T-FX4-04 (8,6): dano 9, expõe dados de muitos titulares; reprodutibilidade 9, a chamada se repete; explorabilidade 8, uma requisição à API; usuários 9; descoberta 8, a rota é conhecida.

T-FX4-06 (8,2): dano 8, remove conteúdo de terceiros; reprodutibilidade 8; explorabilidade 8, uma requisição autenticada; usuários 8; descoberta 8.

Conclusão do fluxo. As ameaças mais graves (T-FX4-04 e 06) decorrem de verificação de função desigual entre rotas, com exposição de dados de vários titulares. A correção é uma matriz de papéis aplicada no servidor, com negação por padrão e registro das ações.

7 VISÃO CONSOLIDADA

A ordenação agrega os 25 cenários pelo mesmo critério. Dezoito atingiram risco alto e sete se apoiam em seis achados da M1. A maior pontuação é da injeção no login (9,8); a segunda, a atribuição de papel no cadastro (9,0). Parametrizar a autenticação corrige o mecanismo de injeção, mas as falhas de controle de acesso ainda exigem autorização no ponto que lê ou altera cada recurso.

Quadro 17 — Top 10 por média DREAD

#	Cenário (elemento principal)	DREAD	Status
1	T-FX1-02 Injeção SQL na autenticação (P2)	9,8	T1 · V1
2	T-FX2-06 Papel privilegiado no cadastro (P3)	9,0	Plausível*
3	T-FX2-01 Resposta previsível no reset (P3)	8,8	T1 · V7
4	T-FX1-04 Hash de senha no JWT (F10)	8,6	T1 · V2
5	T-FX4-04 Consulta de usuários (F16)	8,6	Plausível
6	T-FX3-06 Leitura da cesta de outro titular (P4)	8,4	T1 · V3
7	T-FX1-06 Chave de assinatura distribuída (P2)	8,4	Plausível
8	T-FX4-06 Exclusão de feedback (P5)	8,2	Plausível
9	T-FX1-01 Tentativas repetidas no login (P2)	8,0	T1 · V6
10	T-FX3-02 Checkout de cesta alheia (P4)	7,8	Plausível

Fonte: elaboração própria. *reproduzida na M2 (Seção 8).

Distribuição por categoria STRIDE: Information Disclosure concentra 5 cenários e as demais categorias, 4 cada, totalizando 25. Por tipo de elemento, 16 têm processo como principal, 5 armazenamento e 4 fluxo, o que reflete a localização das decisões de autenticação, autorização e tratamento de dados.

Quadro 18 — Plano de mitigação por frentes

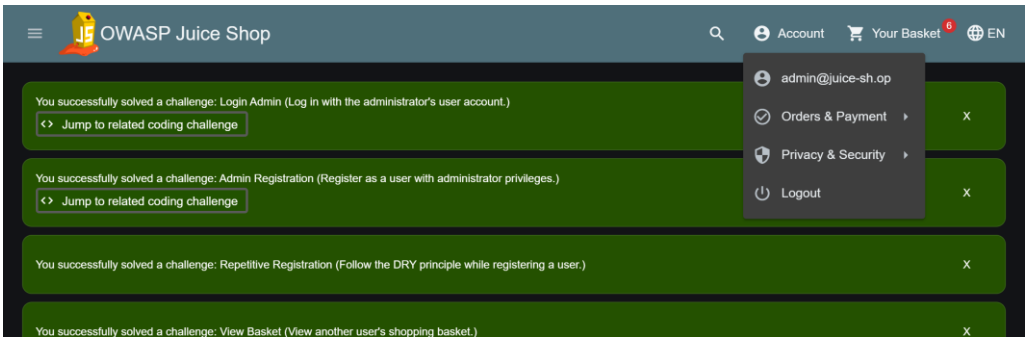
Frente	Tratamento e critério de aceite
1 — Autenticação e segredos	Parametrizar consulta, restringir claims, migrar hash e rotacionar chave. Aceite: a entrada V1 falha; nenhum JWT contém hash.
2 — Cadastro e recuperação	Papel no servidor; recuperação de uso único; resposta uniforme. Aceite: cadastro força customer; reset não enumera contas.
3 — Autorização em P4 e P5	Política de função e de titularidade por objeto. Aceite: duas contas não acessam recursos uma da outra.
4 — Sessão e contenção	Expiração, revogação e limites por conta e origem. Aceite: replay após logout/expiração falha.
5 — Integridade e disponibilidade	Idempotência, quota de PDF e paginação. Aceite: reenvio não duplica pedido; listagens respeitam limite.
6 — Auditoria e erros	Trilha protegida e correlacionável; erro sem detalhe interno. Aceite: eventos com dados mínimos.

Fonte: elaboração própria.

8 VALIDAÇÃO E LIMITAÇÕES

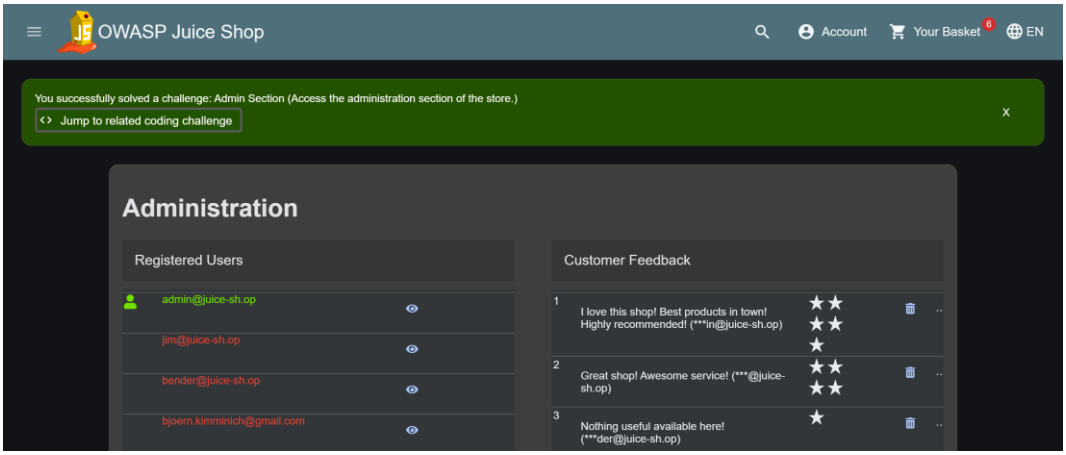
A conferência comparou os pontos de entrada dos diagramas com o código e com os pares HTTP da M1, que sustentam a injeção no login, o hash no JWT, a leitura de cesta alheia, o erro verboso, a listagem em /ftp/, a sequência de falhas de autenticação e o reset com resposta previsível. Em 8 de novembro de 2026 a equipe reimplantou a mesma imagem (digest conferido) em 127.0.0.1:3000 e reproduziu, na instância local, a injeção no login (sessão admin, id 1), o hash no JWT (sem expiração), o cadastro com papel privilegiado (T-FX2-06, antes plausível), a leitura de cesta de outro titular (200 com token de outra conta; 401 sem token), a listagem anônima de /ftp/ e a cota de 100 no reset. O motor de desafios da própria aplicação registrou como resolvidos Login Admin, Admin Registration, View Basket e Error Handling.

Figura 7 — Sessão de administrador obtida por injeção SQL (reprodução M2)



Fonte: elaboração própria.

Figura 8 — Painel /#/administration com a lista de usuários (reprodução M2)



Fonte: elaboração própria.

Limitações. A base de observação direta corresponde aos artefatos da M1, complementados pela reexecução de 08/11/2026. Não houve ensaio de carga, expiração, revogação ou concorrência, nem avaliação de todas as rotas privilegiadas, e as capturas completas de checkout dependem de nova observação. A revisão cruzada entre integrantes e a

validação funcional das hipóteses são as próximas verificações que podem alterar o status ou a prioridade dos cenários.

9 CONCLUSÃO

A modelagem localizou quatro funções em que uma decisão do servidor tem efeito direto sobre conta, cesta, pedido ou operação privilegiada. As evidências concentram-se em pontos diferentes: a injeção altera a consulta que determina a identidade; o hash decorre da serialização da conta no JWT; a leitura de cesta alheia ocorre depois que a sessão foi aceita; a recuperação combina pergunta consultável com prova previsível. A prioridade é corrigir a autenticação, limitar o material emitido na sessão e impedir que o cadastro atribua papéis, estendendo o controle de acesso às APIs administrativas, às referências do checkout e à entrega de comprovantes. Os critérios de aceite permitem conferir cada medida com contas de teste; a lição central da passagem da M1 para a M2 é que reconhecer a sessão não garante a titularidade do recurso.

REFERÊNCIAS

ALVES, Luis Fernando et al. Modelagem de ameaças com STRIDE e DREAD: uma análise preliminar aplicada a um sistema IoT. In: ESCOLA REGIONAL DE ENGENHARIA DE SOFTWARE, 8., 2024. Anais [...]. Porto Alegre: SBC, 2024. p. 218-227. DOI 10.5753/eres.2024.4319.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018.

CARNEIRO, Cinara G. de M.; KUDO, Taciana N.; BULCÃO NETO, Renato de F. Um método para transformação de requisitos legais em padrões de requisitos de software: um estudo com a LGPD. In: CIBSE, 27., 2024, Curitiba. Anais [...]. Porto Alegre: SBC, 2024. p. 348-355. DOI 10.5753/cibse.2024.28460.

HERNAN, Shawn et al. Uncover security design flaws using the STRIDE approach. MSDN Magazine, nov. 2006.

MANADHATA, Pratyusa K.; WING, Jeannette M. An attack surface metric. IEEE Transactions on Software Engineering, v. 37, n. 3, p. 371-386, 2011. DOI 10.1109/TSE.2010.60.

MEIER, J. D. et al. Threat modeling. In: Improving web application security: threats and countermeasures. Microsoft, 2003. cap. 3.

MITRE. Common Weakness Enumeration (CWE). [S. l.]: MITRE, [s. d.].

OWASP FOUNDATION. OWASP Application Security Verification Standard. Versão 5.0.0. [S. l.]: OWASP, 2025.

OWASP FOUNDATION. OWASP Top 10:2021. [S. l.]: OWASP, 2021.

OWASP JUICE SHOP. Código-fonte e testes da versão v20.2.0. [S. l.]: OWASP, 2026.

SCANDARIATO, Riccardo; WUYTS, Kim; JOOSEN, Wouter. A descriptive study of Microsoft's threat modeling technique. Requirements Engineering, v. 20, n. 2, p. 163-180, 2015. DOI 10.1007/s00766-013-0195-2.

SHOSTACK, Adam. Threat modeling: designing for security. Indianapolis: Wiley, 2014.

SILVA, Diego F. da et al. Case prático 1: avaliação de vulnerabilidades em aplicação web. Itajaí: UNIVALI, 2026.

SOUPPAYA, Murugiah; SCARFONE, Karen; DODSON, Donna. Secure Software Development Framework (SSDF) v1.1. Gaithersburg: NIST, 2022. NIST SP 800-218.

TUMA, Katja; ÇALIKLI, Gül; SCANDARIATO, Riccardo. Threat analysis of software systems: a systematic literature review. Journal of Systems and Software, v. 144, p. 275-294, 2018. DOI 10.1016/j.jss.2018.06.073.